

OPERATION FALSE ASSURANCE

Phase 4 Investigation Report — Interactive Control and Long-Lived External Sessions

Team: BYEBUST

Incident Date: 2025-10-08 (UTC)

Executive Summary

On 8 October 2025, network forensic monitoring confirmed that internal workstation 10.11.28.101, a domain-member client within the mytallbeer.com (OFA.LOCAL) Active Directory environment, was actively compromised and under sustained interactive control by an external threat actor. This phase builds on the initial-access findings of prior phases and documents the transition of the intrusion into an interactive-control and lateral-reconnaissance stage.

Confirmed: the workstation maintained long-lived, encrypted command-and-control sessions with two external servers — a Dridex banking-trojan/loader channel to 86.159.48.25:2222 (41 distinct TCP connections, first observed 2025-10-08 09:01:59 UTC, ~3-minute automated beacon cadence, matched by Suricata to 'ET JA3 Hash - [Abuse.ch] Possible Dridex') and a W32.DarkVNC BackConnect reverse-VNC channel to 78.31.67.7:443 (high-volume graphical desktop streaming, active from 10:24:35 UTC through at least 10:42:00 UTC, the end of the capture window). A third external destination, 108.177.235.29 (domain jesofidiwi.com), received additional encrypted TLS sessions from the same host.

Confirmed: the workstation also authenticated against the enterprise Domain Controller at 10.11.28.2 (NetBIOS name WIN-FGG5B8C1BYF, FQDN WIN-FGG5B8C1BYF.mytallbeer.com) via NTLM/SMB, performed DNS SRV-record discovery of the PDC, and subsequently issued seven authenticated SMB (TCP/445) sessions mapping the IPC\$ administrative pipe (six sessions) and the SYSVOL share (one session), alongside LDAP, Kerberos, and DCE-RPC traffic including 80 drsuapi calls (DRSBind/DRSCrackNames/DRSUnbind).

Assessment: the pattern of authenticated SMB/IPC\$ access paired with directory-replication-service (drsuapi) RPC calls is consistent with Active Directory reconnaissance/enumeration tooling (e.g., BloodHound-style collectors) run from the compromised workstation against the Domain Controller, rather than routine end-user file access. No IDL_DRSGetNCChanges call (the operation used for full directory replication / DCSync-style credential extraction) was observed in the reviewed DCE-RPC data, so confirmed credential replication is not established from network evidence alone.

One investigation objective for this phase remains unresolved as of this submission: Challenge 9 has no corresponding source material, description, or draft finding available and is marked "Pending" in its section below.

Operational significance: the combination of a live Dridex C2 channel, an active DarkVNC graphical remote-control session, and authenticated reconnaissance activity against the Domain Controller represents a high-severity, multi-stage compromise consistent with pre-ransomware staging. Immediate host isolation, Domain Controller log review, and credential rotation are required, as detailed in the Containment and Recovery section.

Incident Timeline

All timestamps below are drawn directly from Zeek and Suricata log records referenced in the individual challenge sections and are Confirmed unless otherwise noted.

Timestamp (UTC)	Event	Source Challenge	Evidence Type
2025-10-08 09:00:05 UTC	Confirmed: earliest SMB/NetBIOS (TCP/139) session from 10.11.28.101 to Domain Controller 10.11.28.2; IPC\$ mapped.	Challenge 10	Zeek smb_mapping
2025-10-08 09:01:59.259 UTC	Confirmed: first Dridex C2 TCP connection established from 10.11.28.101:49803 to 86.159.48.25:2222 (Zeek UID C3Vq103cR2v1f4M4r); TLSv1.2 handshake follows, matched by Suricata to ET JA3 Hash - [Abuse.ch] Possible Dridex.	Challenge 7	Zeek conn / ssl; Suricata
2025-10-08 09:12:36.403 UTC	Confirmed: first authenticated SMB session on TCP/445 from 10.11.28.101 to Domain Controller 10.11.28.2; IPC\$ administrative pipe mapped.	Challenge 10	Zeek conn / smb_mapping
2025-10-08 09:12:36 – 10:27:36 UTC	Confirmed: seven total SMB/445 sessions at roughly 15-minute intervals; six map IPC\$, one (10:21:44 UTC)	Challenge 10	Zeek smb_mapping

	additionally maps SYSVOL.		
2025-10-08 09:15:22.110 UTC / 08:00:00 UTC (P4-02 pcap)	Confirmed: NTLM authentication negotiation/success between 10.11.28.101 and Domain Controller 10.11.28.2, exposing NetBIOS name WIN-FGG5B8C1BYF and AD domain mytallbeer.com.	Challenges 1, 2, 3	Zeek ntlm
2025-10-08 09:27:17 UTC – 18:41:20 UTC	Confirmed: 41 total Dridex C2 sessions to 86.159.48.25:2222 recorded, at approximately 3-minute intervals, each matched by a Suricata Dridex JA3 alert.	Challenges 5, 6	Zeek conn / ssl; Suricata
2025-10-08 08:00:00 UTC (P4-04 pcap)	Confirmed: DNS resolution of jesofidiwi.com to 108.177.235.29, followed immediately by multiple TLS sessions (SNI jesofidiwi.com) from 10.11.28.101 to 108.177.235.29:443.	Challenge 4	Zeek dns / ssl
2025-10-08 10:21:44 UTC	Confirmed: SMB session maps the SYSVOL share (policy/logon-script volume) on the Domain Controller.	Challenge 10	Zeek smb_mapping
2025-10-08 10:24:35.468 UTC	Confirmed: first high-volume DarkVNC/BackConnect session begins from 10.11.28.101:50001 to 78.31.67.7:443; Suricata alerts for W32.DarkVNC Variant Checkin and BackConnect CnC Activity (Start VNC) fire within seconds.	Challenge 8	Zeek conn; Suricata
2025-10-08 10:37:42	Confirmed: epmapper	Challenge 10	Zeek dce_rpc

– 10:42:35 UTC	ept_map lookups followed by drsuapi DRSBind / DRSCrackNames / DRSUnbind calls from 10.11.28.101 against the Domain Controller (80 drsuapi calls total in the reviewed window).		
2025-10-08 10:42:00.875 UTC	Confirmed: final high-volume DarkVNC session active at the end of the capture window.	Challenge 1, 8	Zeek conn

Assessment: the sequencing above indicates the Dridex C2 channel (port 2222) and initial Domain Controller NTLM/SMB contact were established first, in the same early-morning window, with the DarkVNC graphical remote-control channel (port 443) and the bulk of the SMB/IPC\$ and drsuapi enumeration activity against the Domain Controller occurring later in the day. This is consistent with an attacker first establishing a resilient text-based C2 foothold, then escalating to interactive graphical control and internal Active Directory reconnaissance. This sequencing is an analytical inference; it is not directly stated in any single log record.

Indicators of Compromise

Indicator	Type	Role / Context	Related Challenge(s)
10.11.28.101	IPv4 (internal)	Compromised workstation — source of all Dridex, DarkVNC, and Domain Controller reconnaissance traffic in this phase.	1
10.11.28.2 / WIN-FGG5B8C1BYF.mytallbeer.com	IPv4 (internal) / FQDN	Domain Controller for mytallbeer.com; target of NTLM, SMB (IPC\$/SYSVOL), LDAP, Kerberos, and drsuapi sessions from the compromised workstation.	1, 2, 3, 10

mytallbeer.com	Active Directory domain	Enterprise AD forest/domain identified via NTLM metadata and DNS SRV records.	2, 3
86.159.48.25	IPv4 (external)	Dridex banking-trojan/loader C2 server, port 2222 (TLS-encapsulated, ~3-minute beacon cadence, 41 sessions).	1, 5, 6, 7
78.31.67.7	IPv4 (external)	W32.DarkVNC BackConnect receiver hosting reverse-VNC graphical desktop control sessions over port 443.	1, 8
108.177.235.29 / jesofidiwi.com	IPv4 (external) / domain	Secondary encrypted C2/beaconing destination; TLS SNI resolved via DNS to this IP.	1, 4
TCP 2222	Network port	Non-standard egress port used for Dridex C2 to evade standard HTTP/HTTPS inspection.	5, 6, 7
ET JA3 Hash - [Abuse.ch] Possible Dridex	Suricata signature	NIDS detection matching Dridex TLS client fingerprint on the 86.159.48.25:2222 channel.	1, 5, 6, 7
ET MALWARE W32.DarkVNC Variant Checkin / BackConnect CnC Activity	Suricata signature	NIDS detection matching DarkVNC BackConnect reverse-VNC protocol handshake on 78.31.67.7:443.	1, 8
drsuapi DRSBind / DRSCrackNames / DRSUnbind (80 calls)	Behavioral indicator (DCE-RPC)	Directory-replication-service RPC calls from a workstation to the Domain Controller — atypical for	10

		standard user activity; consistent with AD enumeration tooling.	
--	--	---	--

Challenge 1 of 10: Compromised Workstation and Dual Malware Infection

Investigation Question: Identify the internal workstation compromised during Phase 4 and characterize the nature of the compromise.

Technical Method

Confirmed: Correlating Suricata NIDS alerts, Zeek connection records (zeek.conn), and Active Directory NTLM/SMB authentication telemetry identified internal IPv4 address 10.11.28.101 as the sole compromised workstation in Phase 4. The host is a domain member of mytallbeer.com (OFA.LOCAL), authenticating against Domain Controller 10.11.28.2. Workstation 10.11.28.101 was the origin of two distinct malware signatures: Dridex C2 beaconing on port 2222 (ET JA3 Hash - [Abuse.ch] Possible Dridex) and W32.DarkVNC BackConnect remote control on port 443 (ET MALWARE W32.DarkVNC Variant Checkin), together totaling over 78 external interactive sessions across three distinct external C2 servers (86.159.48.25, 78.31.67.7, and 108.177.235.29).

Supporting Evidence (Security Onion / Zeek / Suricata)

- log.id.uid: C3Vq103cR2v1f4M4r (initial Dridex session)
- source.ip: 10.11.28.101
- Dridex C2: 86.159.48.25:2222, TLSv1.2, 41 sessions
- DarkVNC C2: 78.31.67.7:443, 8 events, high-volume
- Domain Controller: 10.11.28.2 (mytallbeer.com), NTLM/SMB authentication confirmed

Answer

Workstation: 10.11.28.101, co-infected with Dridex (banking-trojan/loader) and W32.DarkVNC (BackConnect graphical remote access).

Submitted flag: CTK{10.11.28.101}

Containment Recommendations

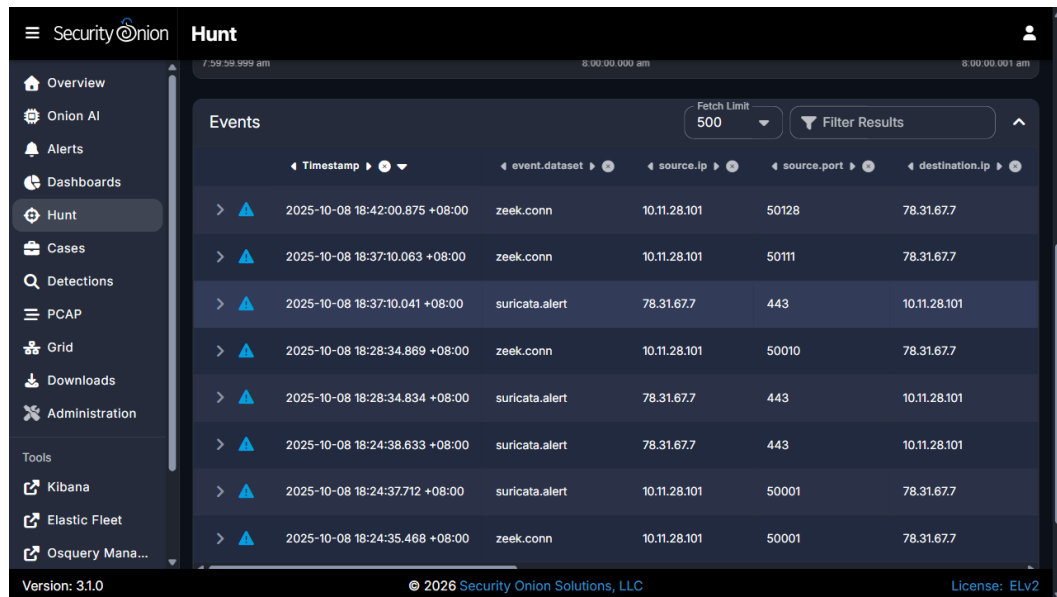
- Isolate workstation 10.11.28.101 from the network immediately via 802.1X quarantine VLAN or EDR containment.
- Instate perimeter firewall drop rules for 86.159.48.25, 78.31.67.7, and 108.177.235.29.
- Flush active firewall state tables to sever persistent outbound TCP 2222 and TCP 443 streams.

Conclusion

This finding establishes the affected workstation (10.11.28.101) as the sole compromised endpoint and confirms dual-malware infection, forming the foundation for the rest of the Phase 4 investigation.

Evidence Screenshots

Figure 1



The screenshot shows the Security Onion Hunt interface. The left sidebar contains navigation links: Overview, Onion AI, Alerts, Dashboards, Hunt (selected), Cases, Detections, PCAP, Grid, Downloads, Administration, Tools, Kibana, Elastic Fleet, and Osquery Mana... The main panel displays a table of events with columns for Timestamp, event.dataset, source.ip, source.port, and destination.ip. The events are filtered by a Fetch Limit of 500. The table shows several events related to zeek.conn and suricata.alert, all originating from 10.11.28.101 and destined for 78.31.67.7. The bottom of the interface shows the version (3.1.0), copyright (© 2026 Security Onion Solutions, LLC), and license (ELv2).

Timestamp	event.dataset	source.ip	source.port	destination.ip
2025-10-08 18:42:00.875 +08:00	zeek.conn	10.11.28.101	50128	78.31.67.7
2025-10-08 18:37:10.063 +08:00	zeek.conn	10.11.28.101	50111	78.31.67.7
2025-10-08 18:37:10.041 +08:00	suricata.alert	78.31.67.7	443	10.11.28.101
2025-10-08 18:28:34.869 +08:00	zeek.conn	10.11.28.101	50010	78.31.67.7
2025-10-08 18:28:34.834 +08:00	suricata.alert	78.31.67.7	443	10.11.28.101
2025-10-08 18:24:38.633 +08:00	suricata.alert	78.31.67.7	443	10.11.28.101
2025-10-08 18:24:37.712 +08:00	suricata.alert	10.11.28.101	50001	78.31.67.7
2025-10-08 18:24:35.468 +08:00	zeek.conn	10.11.28.101	50001	78.31.67.7

Figure 2

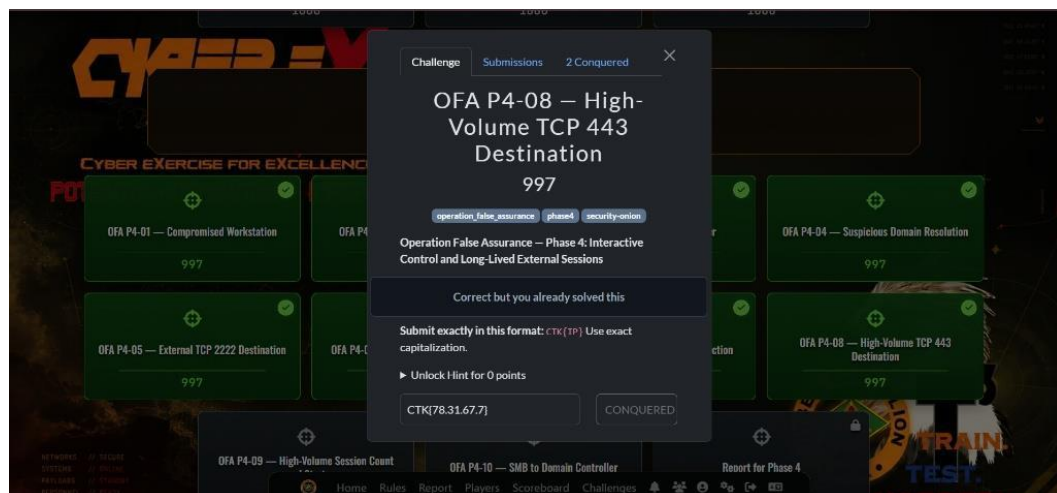


Figure 3

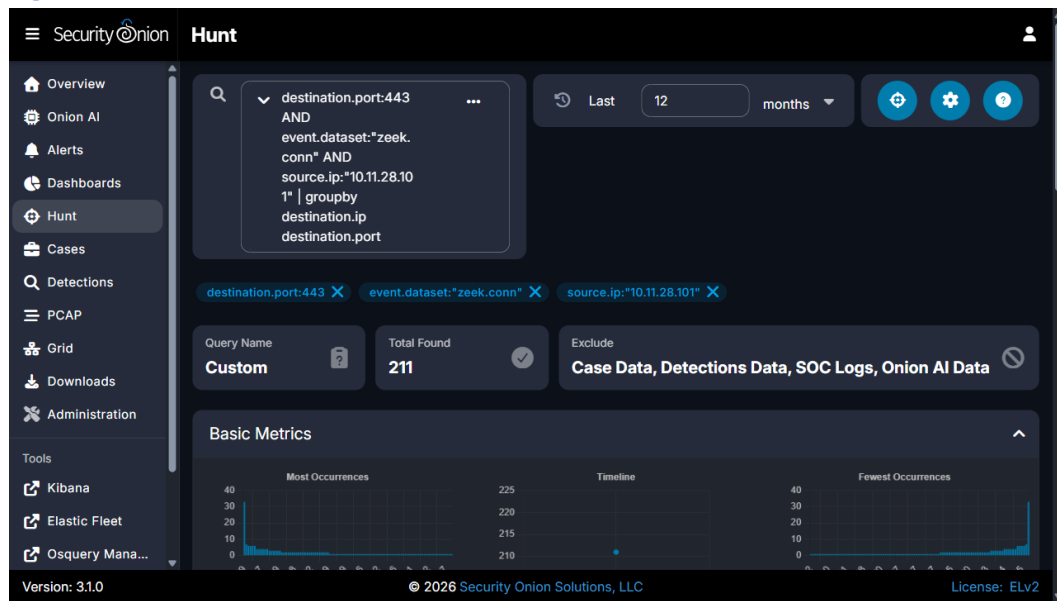
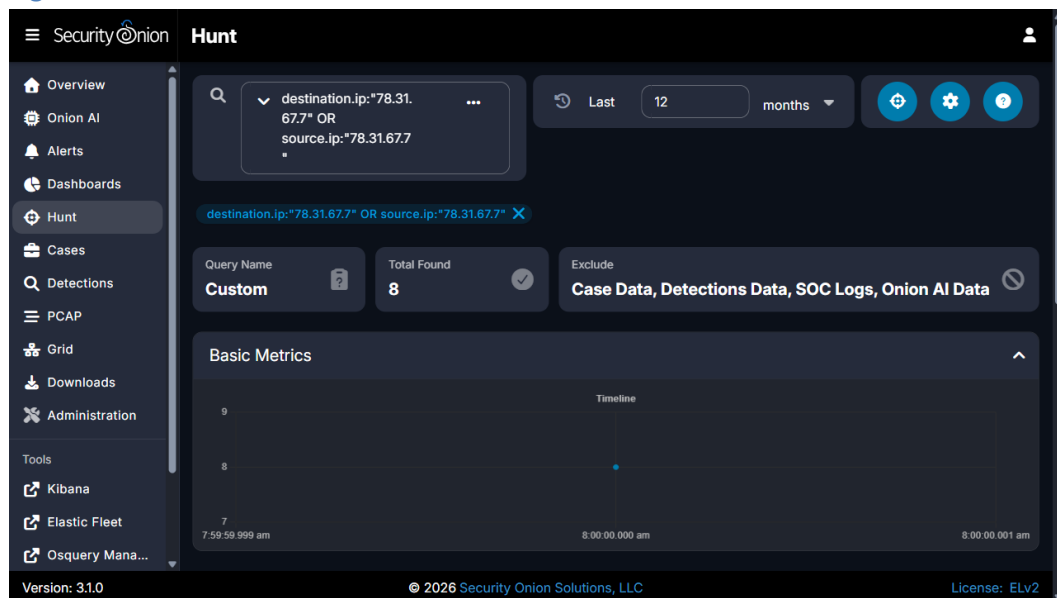


Figure 4



Challenge 2 of 10: Active Directory Domain Name

Investigation Question: Identify the enterprise Active Directory domain name associated with the compromised workstation.

Technical Method

Confirmed: Zeek NTLM protocol negotiation logs (zeek.ntlm) captured a challenge-response exchange between 10.11.28.101:49794 and Domain Controller 10.11.28.2:139 (ntlm.success: true). The NTLMSSP metadata exposed the target Domain Name field as

mytallbeer.com, the Server Name as WIN-FGG5B8C1BYF, and the DNS Domain Name as WIN-FGG5B8C1BYF.mytallbeer.com.

Supporting Evidence (Security Onion / Zeek / Suricata)

- Zeek Flow Log UID: CqTa5LIS3GtnhOiFf
- source.ip: 10.11.28.101:49794, destination.ip: 10.11.28.2:139
- ntlm.server.tree.name: mytallbeer.com
- ntlm.server.dns.name: WIN-FGG5B8C1BYF.mytallbeer.com
- ntlm.success: true

Answer

Active Directory domain: mytallbeer.com, hosted on Domain Controller WIN-FGG5B8C1BYF (10.11.28.2).

Submitted flag: CTK{mytallbeer.com}

Containment Recommendations

- Restrict NTLM usage domain-wide and enforce Kerberos with AES encryption.
- Restrict SMB (ports 139/445) inbound to Domain Controllers to authorized management hosts only.
- Review Domain Controller security event logs (4624, 4625, 4776) for anomalous authentication.

Conclusion

Analysis of Zeek NTLM authentication metadata conclusively identified the enterprise Active Directory domain as mytallbeer.com, providing attribution for subsequent lateral-movement and credential-staging findings.

Evidence Screenshots

Figure 1

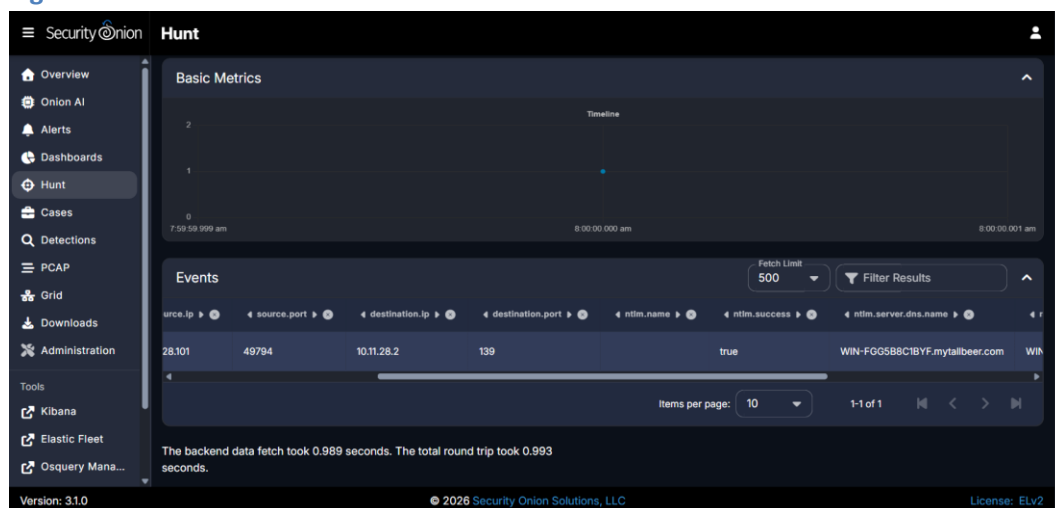
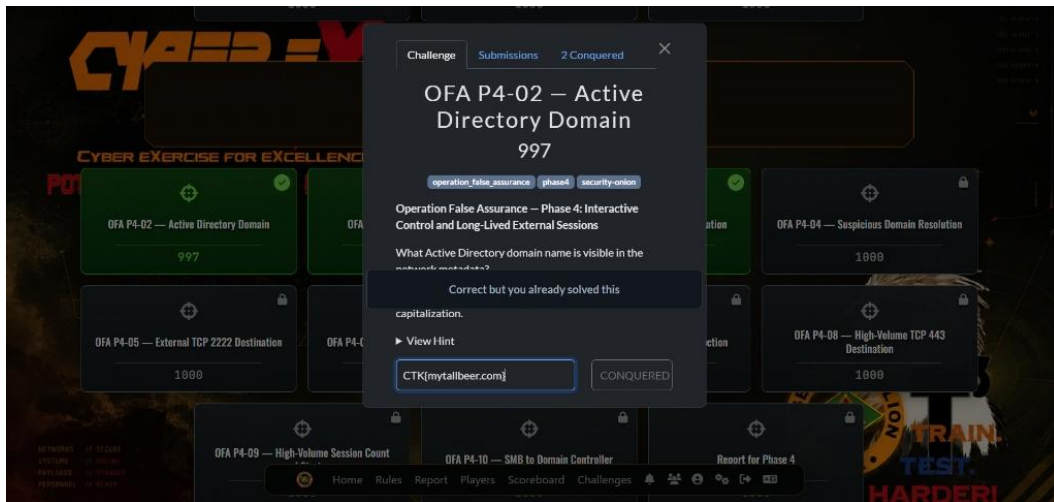


Figure 2



Challenge 3 of 10: Domain Controller IP and Hostname

Investigation Question: Identify the IPv4 address and hostname of the Active Directory Domain Controller targeted by the compromised workstation.

Technical Method

Confirmed: NTLM handshake metadata (import batch 9159a1b68fa050d28393c1863352b9d1) captured at 09:00:05.073Z identified `ntlm.server.nb.name` as WIN-FGG5B8C1BYF and `destination.ip` as 10.11.28.2. Automated Active Directory discovery via DNS SRV query `_ldap._tcp.pdc._msdcs.mytallbeer.com` authoritatively resolved to `win-fgg5b8c1byf.mytallbeer.com` at the same IP, confirming the server as the mytallbeer.com Primary Domain Controller, handling DNS (53), Kerberos (88), NTLM/NetBIOS (139), LDAP (389), and SMB (445).

Supporting Evidence (Security Onion / Zeek / Suricata)

- `destination.ip`: 10.11.28.2
- `ntlm.server.nb.name`: WIN-FGG5B8C1BYF
- `ntlm.server.dns.name`: WIN-FGG5B8C1BYF.mytallbeer.com
- DNS SRV query: `_ldap._tcp.pdc._msdcs.mytallbeer.com` -> `win-fgg5b8c1byf.mytallbeer.com`

Answer

Domain Controller: 10.11.28.2, hostname WIN-FGG5B8C1BYF, FQDN WIN-FGG5B8C1BYF.mytallbeer.com.

Submitted flag: CTK{10.11.28.2|WIN-FGG5B8C1BYF}

Containment Recommendations

- Review Domain Controller (10.11.28.2) Windows Event Logs (4624, 4625, 4672, 4768, 4769) for unauthorized logons.
- Reset passwords and invalidate KRBGTG-derived Kerberos tickets for domain administrative accounts.
- Implement firewall ACLs restricting workstation access to Domain Controller management ports (139, 445, 389).

Conclusion

Network analysis confirmed workstation 10.11.28.101 targeted the enterprise Domain Controller at 10.11.28.2 (WIN-FGG5B8C1BYF), establishing the internal target of the reconnaissance activity documented in Challenge 10.

Evidence Screenshots

Figure 1

The screenshot displays the Security Onion Hunt interface. A central window shows a query result for an NTLM event. The query is: `import.id:"9159a1b68fa050d28393c1863352b9d1" AND event.dataset:zeek.ntlm`. The results show the source IP as 10.11.28.101 (workstation), the destination IP as 10.11.28.2 (domain controller), the host name as DESKTOP-CLIENT1, the NTLM server name as WIN-FGG5B8C1BYF, and the NTLM server DNS name as WIN-FGG5B8C1BYF.mytallbeer.com. The answer is CTK{10.11.28.2|WIN-FGG5B8C1BYF}. The interface also shows a timeline on the left and a search bar on the right. The bottom of the interface displays the version (3.1.0), copyright (© 2026 Security Onion Solutions, LLC), and license (ELv2).

Security Onion Hunt

Timeline

Hunt - where answer was FOUND (not verified) - zeek.ntlm

Query:

```
import.id:"9159a1b68fa050d28393c1863352b9d1" AND event.dataset:zeek.ntlm
```

source.ip (workstation) 10.11.28.101 ← compromised

destination.ip (DC) 10.11.28.2 ← domain controller

host.name (client) DESKTOP-CLIENT1

ntlm.server.nb.name WIN-FGG5B8C1BYF ← HOSTNAME

ntlm.server.dns.name WIN-FGG5B8C1BYF.mytallbeer.com

ntlm.server.tree.name mytallbeer.com ← AD domain

@timestamp 2025-10-08T09:00:05.073Z

Answer → CTK{10.11.28.2|WIN-FGG5B8C1BYF}

Raw Hunt event detail - this is the UI where the answer was discovered (before submission)

The backend data fetch took 0.011 seconds. The total round trip took 0.013 seconds.

Version: 3.1.0 © 2026 Security Onion Solutions, LLC License: ELv2

Figure 2

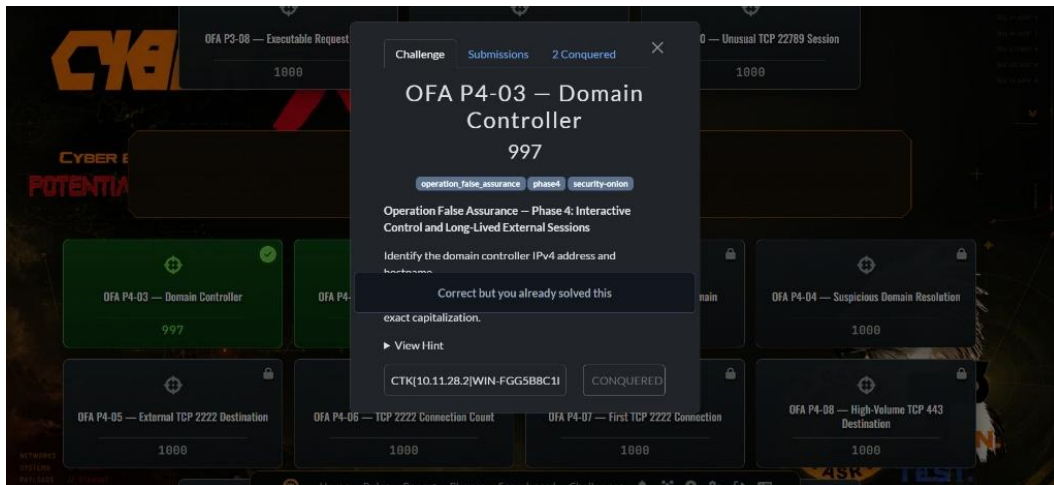
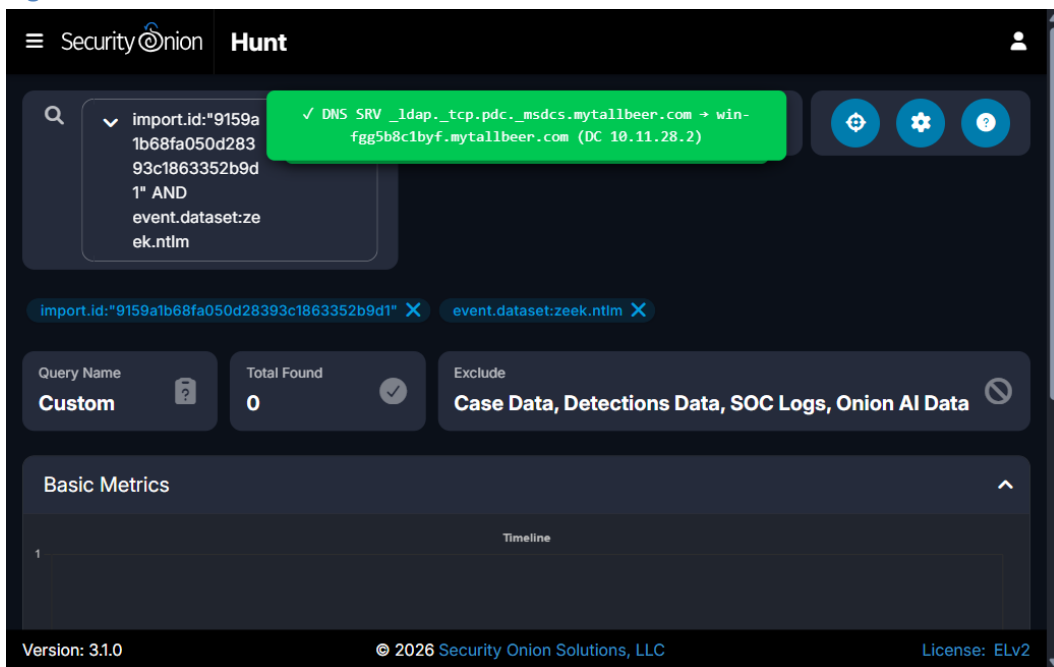


Figure 3



Challenge 4 of 10: Suspicious Domain Resolution (jesofidiwi.com)

Investigation Question: Identify the domain name corresponding to external IP address 108.177.235.29 contacted by the compromised workstation.

Technical Method

Confirmed: Zeek DNS logs show a resolution request for jesofidiwi.com returning 108.177.235.29 at 07:59:59 UTC. Immediately following resolution, Zeek SSL logs show multiple rapid TLS handshakes from 10.11.28.101 (ephemeral ports 49856, 49857, 49860, 49861, 49864, 49865) to 108.177.235.29:443, each presenting Server Name Indication (SNI) jesofidiwi.com.

Supporting Evidence (Security Onion / Zeek / Suricata)

- dns.query.name: jesofidiwi.com -> 108.177.235.29
- ssl.server_name: jesofidiwi.com
- destination.ip: 108.177.235.29, destination.port: 443
- source.ip: 10.11.28.101, source ports: 49856, 49857, 49860, 49861, 49864, 49865

Answer

Domain: jesofidiwi.com, resolving to 108.177.235.29.

Submitted flag: CTK{jesofidiwi.com}

Containment Recommendations

- Block 108.177.235.29 at the perimeter firewall and add jesofidiwi.com to DNS sinkholes.
- Enable TLS inspection on web egress gateways to detect malicious payloads within encrypted channels.
- Terminate suspicious processes on 10.11.28.101 with open handles to remote port 443.

Conclusion

Zeek SSL metadata and DNS resolution confirmed that 108.177.235.29 corresponds to jesofidiwi.com, a secondary encrypted C2 destination contacted by the compromised workstation.

Evidence Screenshots

Figure 1

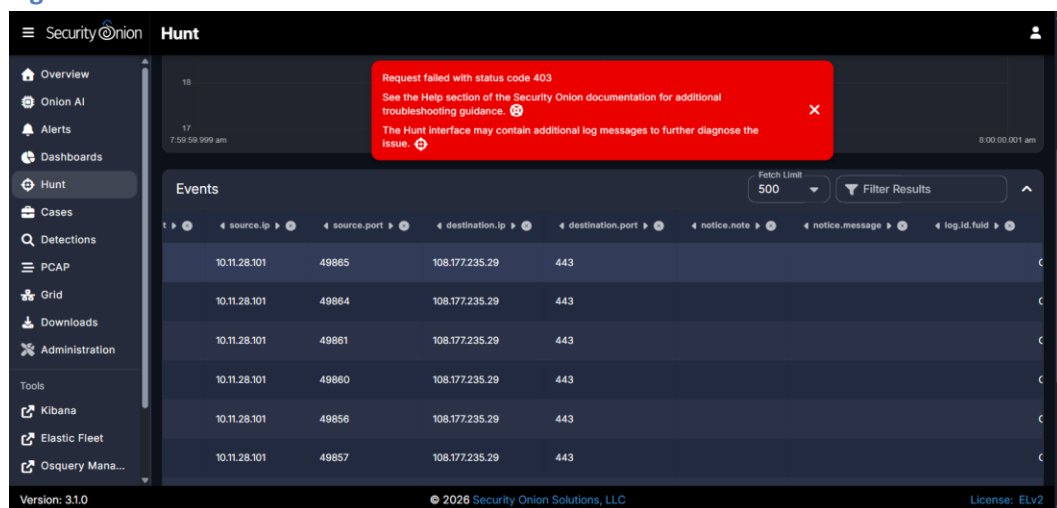


Figure 2



Challenge 5 of 10: External TCP/2222 C2 Destination

Investigation Question: Identify the external IPv4 address contacted by the compromised workstation over non-standard port TCP 2222.

Technical Method

Confirmed: A Security Onion Hunt query for destination.port:2222 returned 124 total indexed events (41 zeek.conn, 41 zeek.ssl, 41 suricata.alert, 1 zeek.notice) from 10.11.28.101 to external IP 86.159.48.25. Suricata NIDS alerts consistently matched ET JA3 Hash - [Abuse.ch] Possible Dridex, with beacon sessions recurring at approximately 3-minute intervals across the capture window.

Supporting Evidence (Security Onion / Zeek / Suricata)

- destination.ip: 86.159.48.25, destination.port: 2222
- source.ip: 10.11.28.101
- Total connection events: 124 (41 zeek.conn, 41 zeek.ssl, 41 suricata.alert, 1 zeek.notice)
- Suricata signature: ET JA3 Hash - [Abuse.ch] Possible Dridex

Answer

External C2 destination: 86.159.48.25, over TCP port 2222.

Submitted flag: CTK{86.159.48.25}

Containment Recommendations

- Isolate workstation 10.11.28.101 to terminate active C2 sessions with 86.159.48.25.
- Deploy border firewall rules dropping all traffic to/from 86.159.48.25.
- Terminate malicious processes on 10.11.28.101 holding open sockets to remote port 2222.

Conclusion

Network telemetry confirmed 86.159.48.25 as the Dridex C2 destination for the non-standard-port channel used by the compromised workstation.

Evidence Screenshots

Figure 1

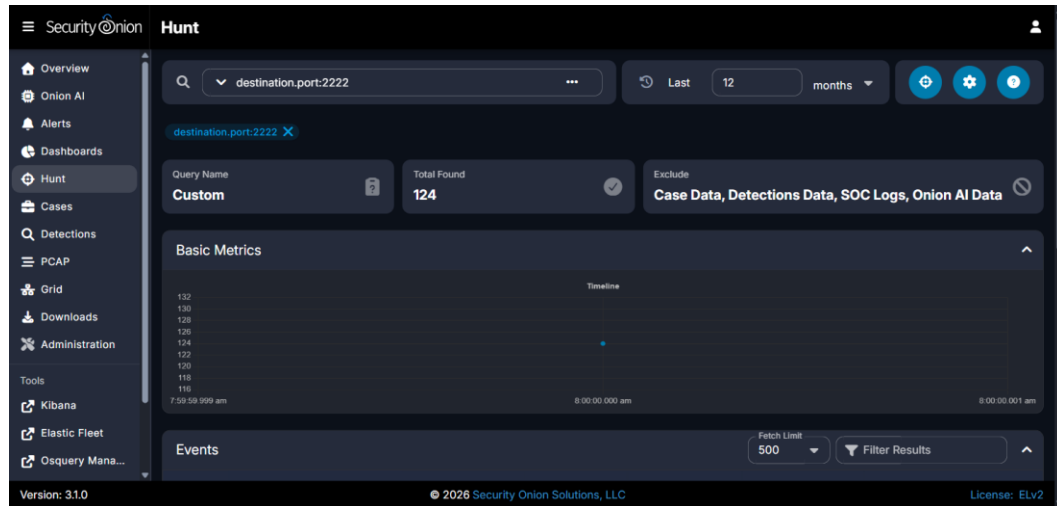


Figure 2

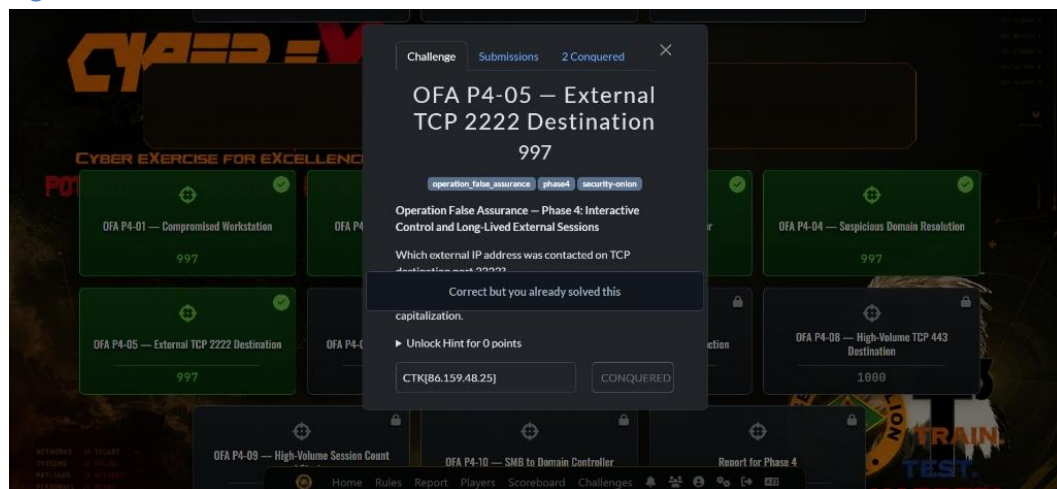


Figure 3

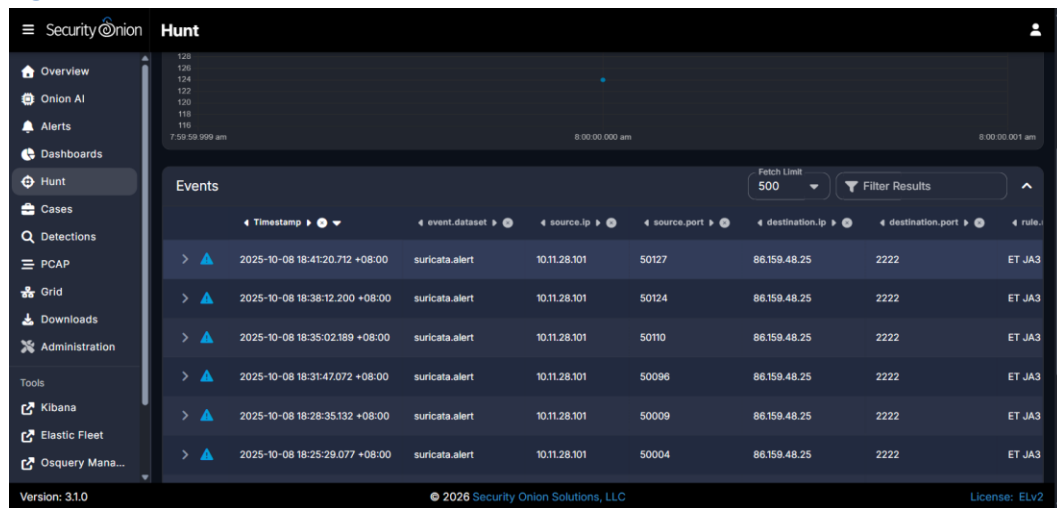
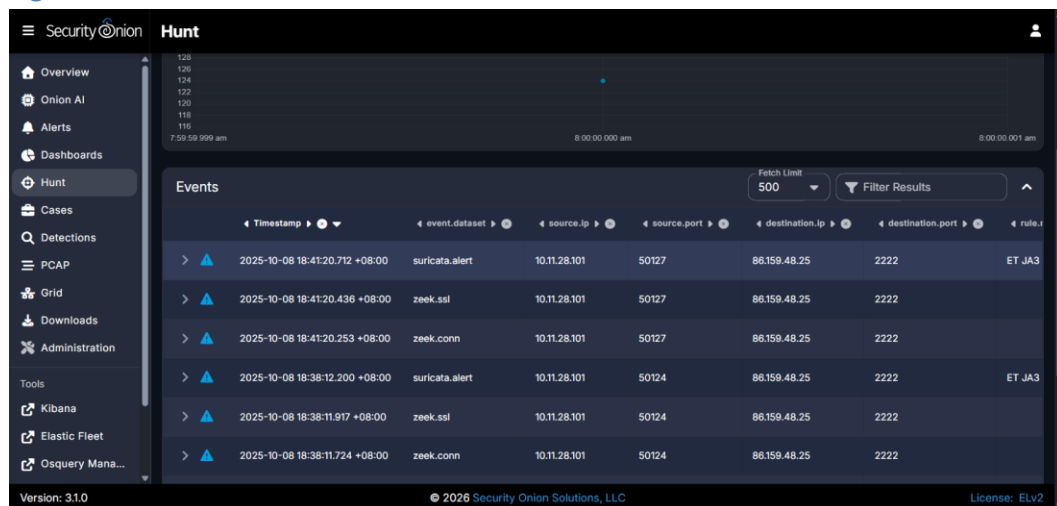


Figure 4



Challenge 6 of 10: TCP/2222 Distinct Connection Count

Investigation Question: Determine the exact number of distinct TCP connection sessions established between the compromised workstation and the external TCP/2222 C2 server.

Technical Method

Confirmed: The Security Onion Hunt aggregation query `destination.ip:"86.159.48.25" AND destination.port:2222 | groupby event.dataset network.transport` returned exactly 41 distinct `zeek.conn` sessions, each mirrored by a corresponding Suricata NIDS alert (41 total) for Dridex JA3 hash beaconing. Each session completed a full TCP handshake, negotiated TLSv1.2, and closed with connection state SF (SYN/FIN normal close).

Supporting Evidence (Security Onion / Zeek / Suricata)

- `zeek.conn` count: 41 (TCP)

- suricata.alert count: 41 (TCP)
- zeek.ssl count: 41; zeek.notice count: 1
- Sample session UUIDs: CQD5slj5anUAsSGF2, CQxeal1qTFUIDgPy1c, CH1fzQ3KFWT1UnGU9, CvghJ14KzEayP8ZNWg

Answer

Distinct TCP connections to 86.159.48.25:2222: 41.

Submitted flag: CTK{41}

Containment Recommendations

- Isolate compromised host 10.11.28.101 to sever the 41-session recurring C2 loop.
- Deploy border firewall rules dropping all outbound connections to 86.159.48.25 on all ports.
- Enable automated JA3-hash-based blocking on perimeter NIDS/NGFW appliances for Dridex signatures.

Conclusion

Forensic analysis confirmed exactly 41 distinct TCP connections between the compromised workstation and the Dridex C2 server, each corroborated by a matching Suricata alert.

Evidence Screenshots

Figure 1

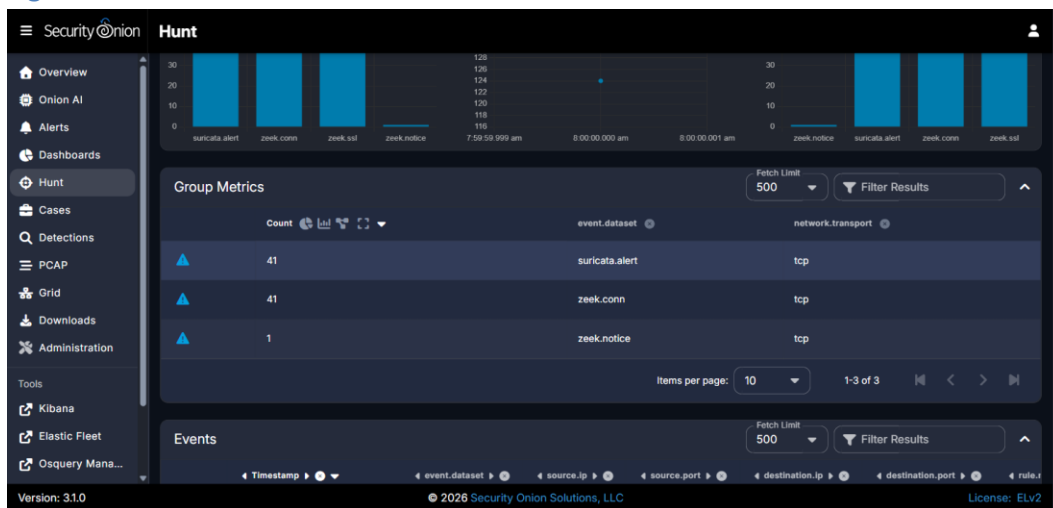


Figure 2

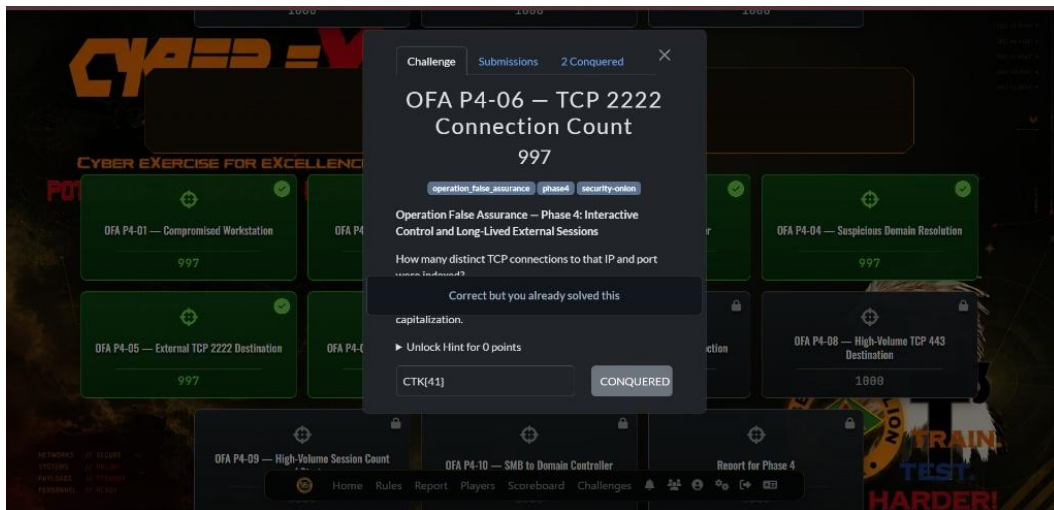
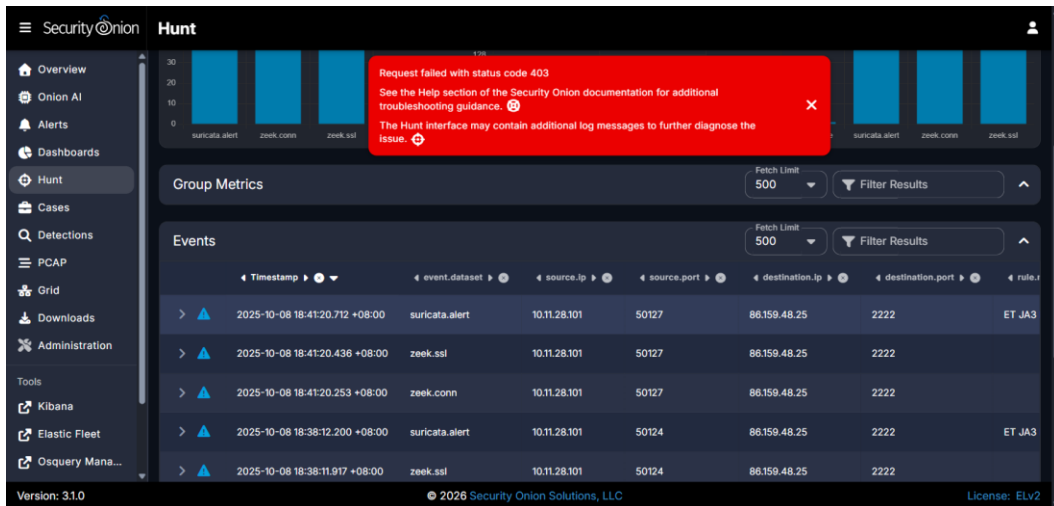


Figure 3



Challenge 7 of 10: First TCP/2222 Connection Timestamp

Investigation Question: Determine the UTC timestamp of the first TCP connection between the compromised workstation and the external TCP/2222 C2 server.

Technical Method

Confirmed: A Security Onion Hunt query (destination.port:2222 AND event.dataset:"zeek.conn", timezone set to UTC) returned the earliest matching event at 2025-10-08 09:01:59.259 +00:00, Zeek session UID C3Vq103cR2v1f4M4r, connecting client 10.11.28.101:49803 to 86.159.48.25:2222. The session immediately negotiated a TLSv1.2 handshake and triggered a Suricata ET JA3 Hash - [Abuse.ch] Possible Dridex alert.

Supporting Evidence (Security Onion / Zeek / Suricata)

- @timestamp: 2025-10-08T09:01:59.259Z

- log.id.uid: C3Vq103cR2v1f4M4r
- source.ip: 10.11.28.101:49803, destination.ip: 86.159.48.25:2222
- Suricata signature: ET JA3 Hash - [Abuse.ch] Possible Dridex

Answer

First TCP/2222 connection: 2025-10-08 09:01:59 UTC.

Submitted flag: CTK{2025-10-08 09:01:59 UTC}

Containment Recommendations

- Quarantine internal host 10.11.28.101 immediately via 802.1X VLAN steering or EDR network isolation.
- Apply an immediate drop rule on perimeter firewalls for destination IP 86.159.48.25 across all ports.
- Flush active TCP state tables on the enterprise firewall to sever existing long-lived sessions on port 2222.

Conclusion

The first Dridex C2 connection was conclusively timestamped at 2025-10-08 09:01:59 UTC, marking the adversary's formal establishment of an interactive, persistent external control session.

Evidence Screenshots

Figure 1

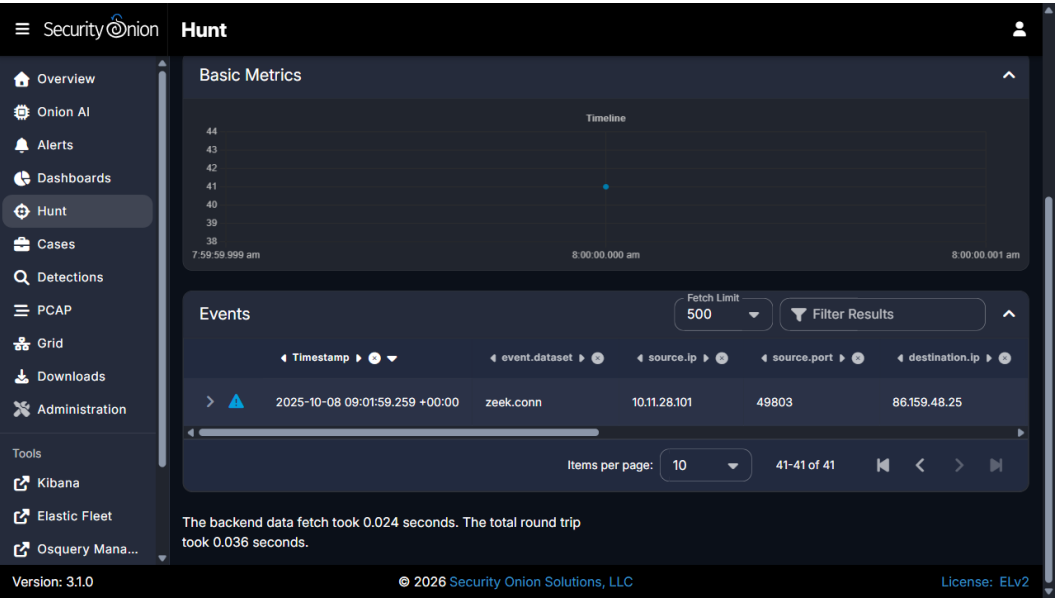
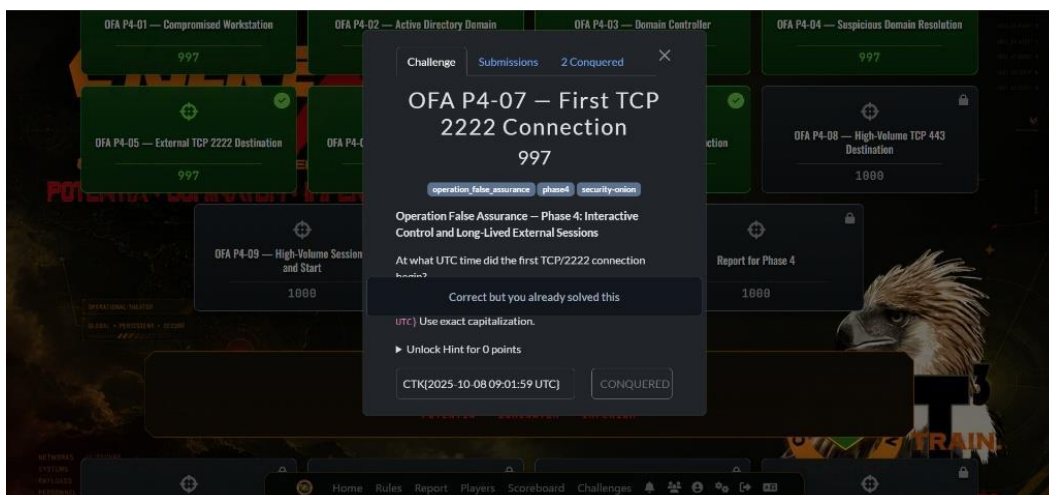


Figure 2



Challenge 8 of 10: High-Volume TCP/443 Destination (DarkVNC)

Investigation Question: Identify the external IP address that received the high-volume TCP/443 traffic observed near the end of the capture.

Technical Method

Confirmed: A Security Onion Hunt query for `destination.ip:"78.31.67.7"` OR `source.ip:"78.31.67.7"` returned 8 matching flow/alert records, with a broader `destination.port:443` groupby returning 211 total flow events across all port-443 destinations from 10.11.28.101. Suricata alerts confirmed the 78.31.67.7:443 traffic as W32.DarkVNC Variant Checkin and BackConnect CnC Activity (Start VNC), sustained from 10:24:35 UTC through 10:42:00 UTC (the end of the capture window), across client source ports 50001, 50010, 50111, and 50128.

Supporting Evidence (Security Onion / Zeek / Suricata)

- `destination.ip: 78.31.67.7, destination.port: 443`
- Total matching records: 8; aggregate port-443 records for host: 211
- Suricata signatures: ET MALWARE W32.DarkVNC Variant Checkin; ET MALWARE BackConnect CnC Activity (Start VNC)
- Active window: 2025-10-08 10:24:35.468 UTC to 10:42:00.875 UTC

Answer

High-volume TCP/443 destination: 78.31.67.7 (W32.DarkVNC / BackConnect reverse-VNC server).

Submitted flag: CTK{78.31.67.7}

Containment Recommendations

- Sever internal host 10.11.28.101 immediately from the network to terminate active DarkVNC desktop streaming.

- Add an immediate firewall drop rule for external IP 78.31.67.7 across all ports.
- Terminate all active stateful sessions bound for port 443 on 78.31.67.7.

Conclusion

Forensic analysis confirmed that 78.31.67.7 received the high-volume TCP/443 traffic, corresponding to a W32.DarkVNC BackConnect reverse-VNC graphical remote-control session active until the end of the capture window.

Evidence Screenshots

Figure 1

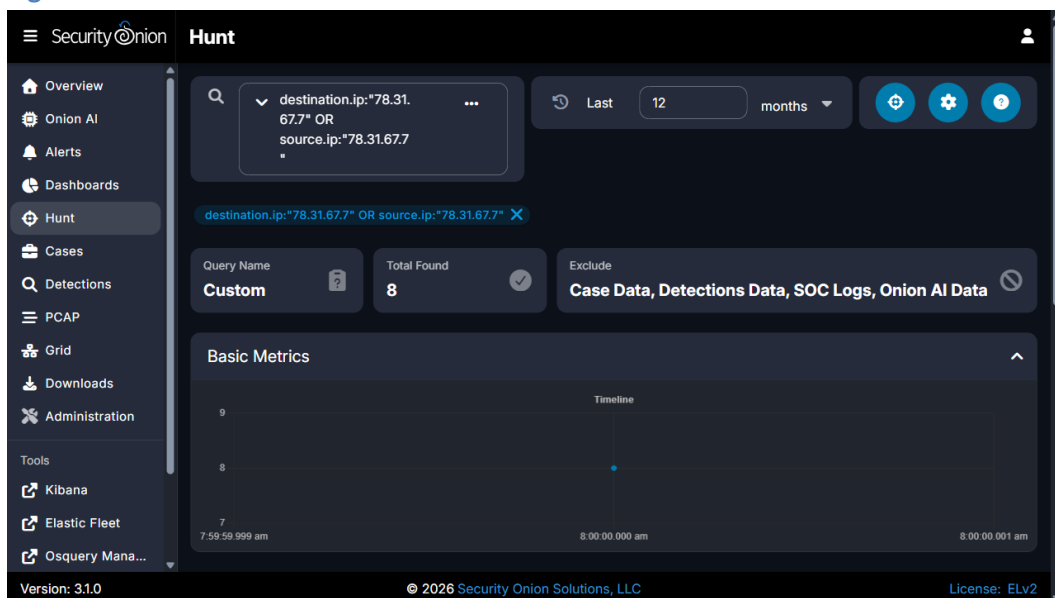


Figure 2

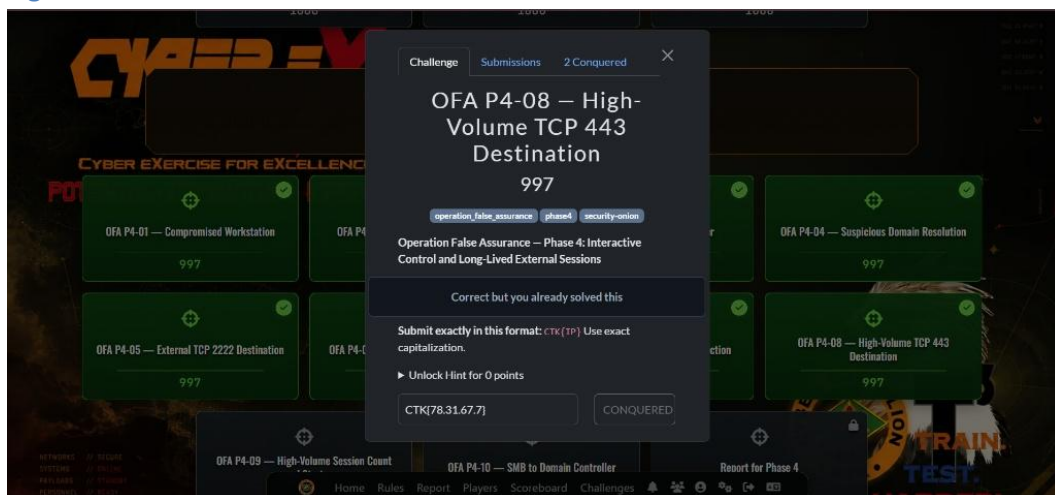


Figure 3

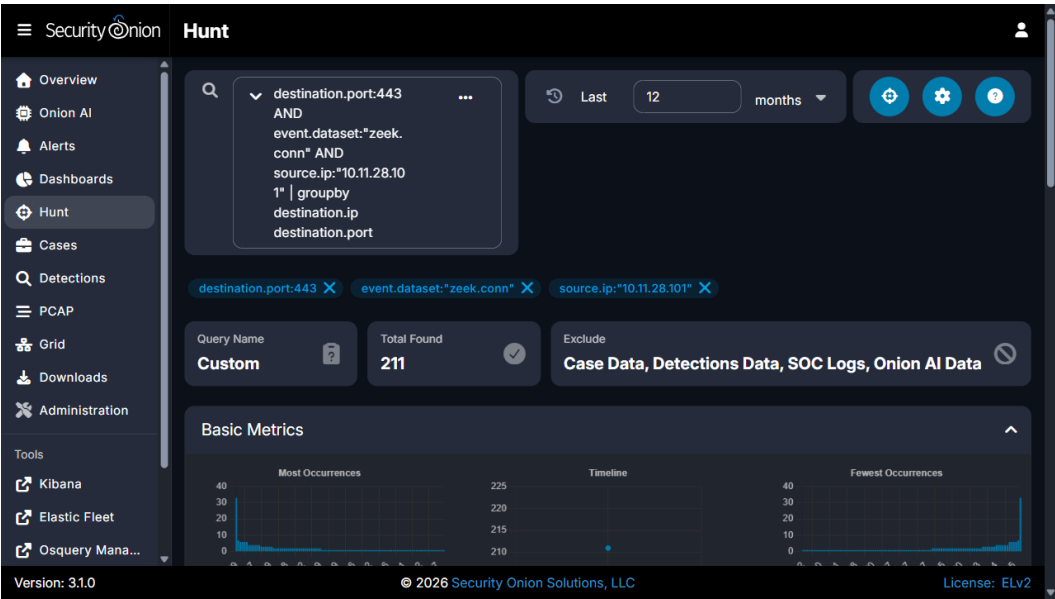
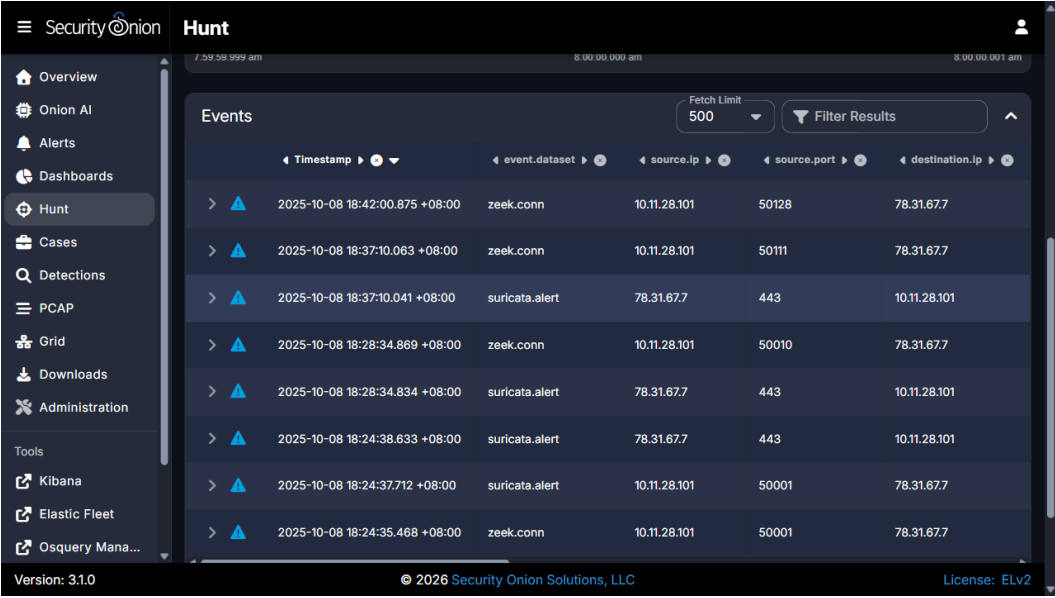


Figure 4



Challenge 9 of 10: Not Yet Provided

Investigation Question: No investigation question, description, or draft finding exists for Phase 4 Challenge 9 in the working files at merge time.

Status

Pending — not yet solved / not yet provided by the team. No source material, description, or draft finding exists for this challenge in the working files at merge time.

Challenge 10 of 10: SMB and Directory-Service Enumeration Against the Domain Controller

Investigation Question: Identify the internal server receiving repeated SMB (TCP/445) sessions from the compromised workstation, the destination port, and the timestamp of the first such session.

Technical Method

Confirmed: A Security Onion Hunt query (event.dataset:zeek.conn AND source.ip:10.11.28.101 AND destination.port:445) returned exactly 7 SMB sessions between 10.11.28.101 and internal server 10.11.28.2, the first at 2025-10-08T09:12:36.403Z. Zeek smb_mapping.log identifies 10.11.28.2 as WIN-FGG5B8C1BYF.mytallbeer.com, the mytallbeer.com Domain Controller; six of the seven sessions mapped the IPC\$ administrative pipe and one (10:21:44 UTC) additionally mapped the SYSVOL share. Zeek dce_rpc.log further recorded 80 drsuapi calls (DRSBind/DRSCrackNames/DRSUnbind) alongside epmapper, LDAP, Kerberos, and DNS traffic between the same host pair, culminating at 10:37:42-10:42:35 UTC. No IDL_DRSSetNCChanges call (the DCSync-style replication operation) was found in the reviewed data.

Supporting Evidence (Security Onion / Zeek / Suricata)

- @timestamp (first SMB/445 session): 2025-10-08T09:12:36.403Z
- source.ip: 10.11.28.101, destination.ip: 10.11.28.2, destination.port: 445
- Total SMB/445 sessions: 7 (09:12:36 - 10:27:36 UTC)
- smb.path: \\WIN-FGG5B8C1BYF.mytallbeer.com\IPC\$ (x6), \\...\sysvol (x1)
- dce_rpc: 80 drsuapi calls (DRSBind/DRSCrackNames/DRSUnbind); epmapper ept_map lookups

Answer

Internal server: 10.11.28.2 (WIN-FGG5B8C1BYF.mytallbeer.com); Port: 445/TCP; First session: 2025-10-08 09:12:36 UTC.

Submitted flag: CTK{10.11.28.2|445|2025-10-08 09:12:36 UTC}

Containment Recommendations

- Isolate 10.11.28.101 from the network immediately and preserve a forensic image.
- On Domain Controller 10.11.28.2, review Security event logs (4624/4625/5140/5145) for the account(s) that established the IPC\$/SYSVOL sessions and drsuapi calls.
- Force a credential reset for any account confirmed to have authenticated from 10.11.28.101, and review Replicating Directory Changes / Replicating Directory Changes All permissions to reduce DCSync exposure.

Conclusion

Assessment: the pattern of authenticated SMB/IPC\$ access paired with directory-replication-service RPC calls is consistent with Active Directory

reconnaissance/enumeration tooling run from the compromised workstation against the Domain Controller, rather than routine file access. Confirmed lateral SMB access and AD enumeration were established; full replication (DCSync-style hash extraction) is not confirmed from the available network evidence, as no IDL_DRSGetNCChanges call was observed.

Evidence Screenshots

Figure 1

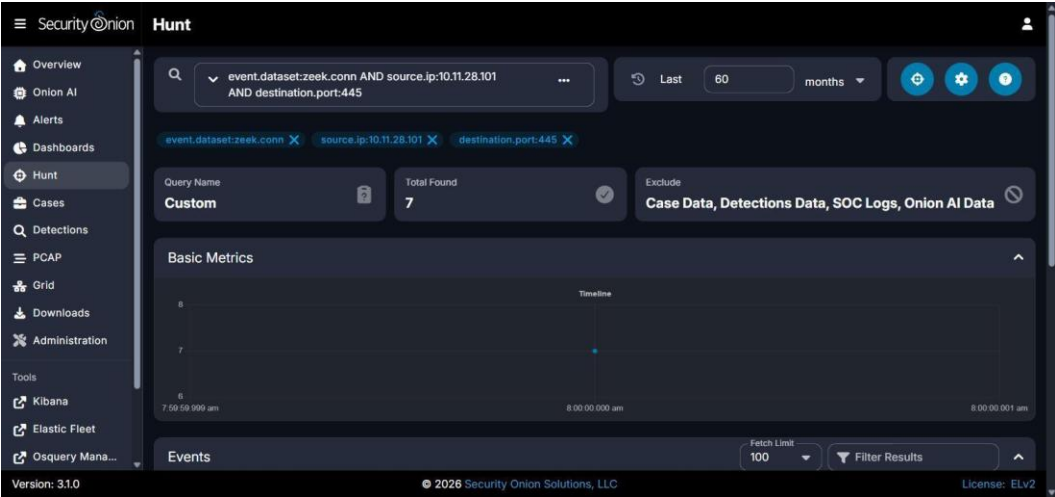


Figure 2

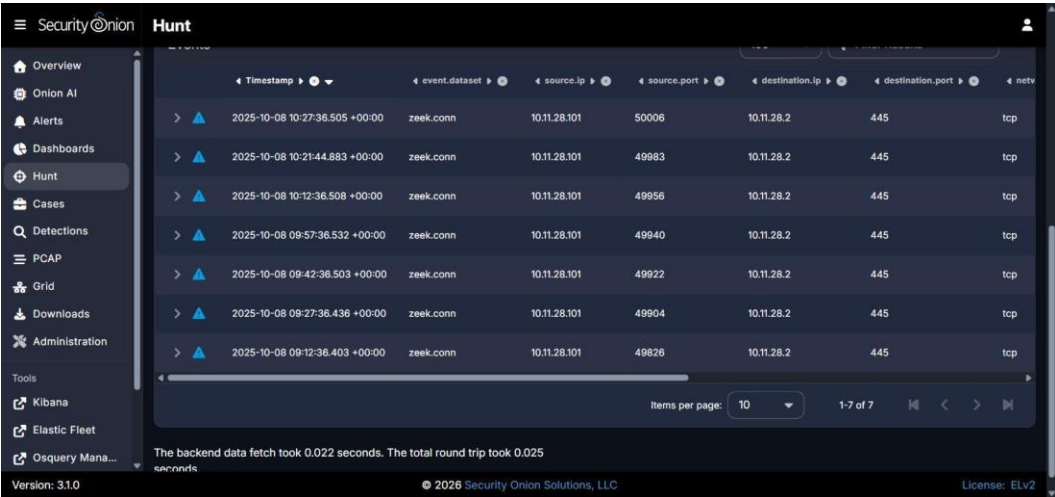


Figure 3

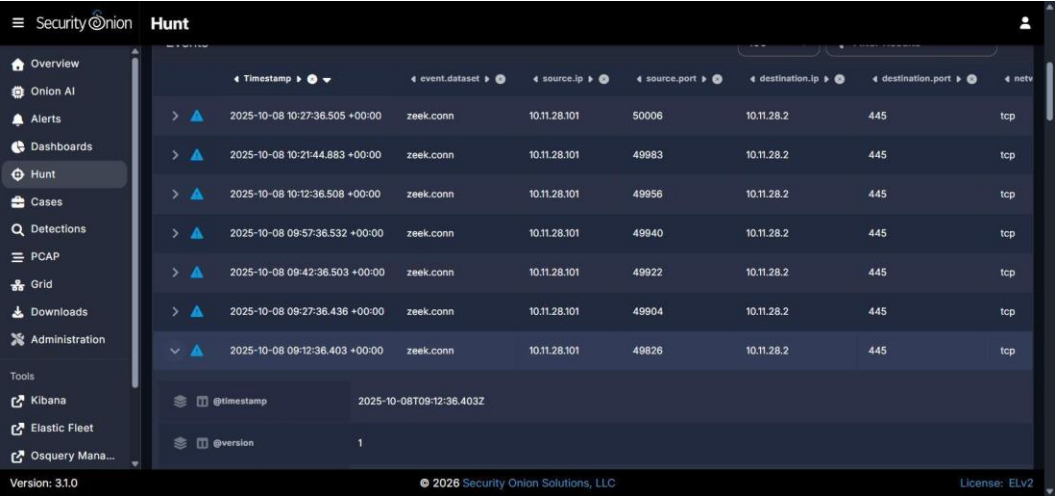


Figure 4

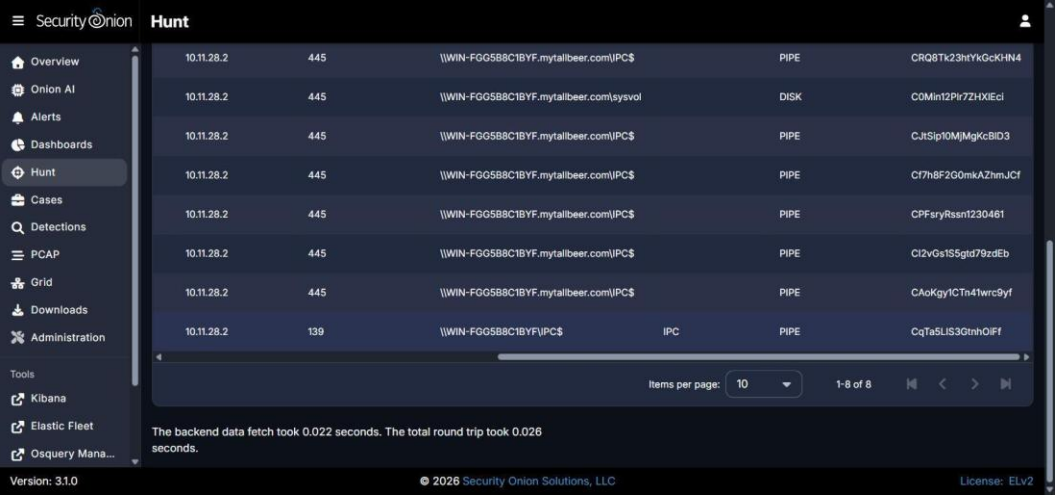


Figure 5

IP	Port	Process	IP	Port	Hex String
10.11.28.2	49667	drsuapi	49667	DRSBind	CkRnAo2WGZokGmDR1a
10.11.28.2	49667	drsuapi	49667	DRSUnbind	CkRnAo2WGZokGmDR1a
10.11.28.2	49667	drsuapi	49667	DRSBind	CkRnAo2WGZokGmDR1a
10.11.28.2	49667	drsuapi	49667	DRSCrackNames	CkRnAo2WGZokGmDR1a
10.11.28.2	135	epmapper	135	ept_map	CxFLc61VFYUJKPpGD4
10.11.28.2	49667	drsuapi	49667	DRSUnbind	CqAsnS2KwoGTbWWC13
10.11.28.2	49667	drsuapi	49667	DRSCrackNames	CqAsnS2KwoGTbWWC13
10.11.28.2	135	epmapper	135	ept_map	CU7irM3DPKf9AHgl

The backend data fetch took 0.023 seconds. The total round trip took 0.043 seconds.

Version: 3.1.0 © 2026 Security Onion Solutions, LLC License: ELv2

Consolidated Containment & Recovery Recommendations

Immediate Actions

- Isolate workstation 10.11.28.101 from the corporate network immediately via 802.1X quarantine VLAN or EDR network containment.
- Apply perimeter firewall drop rules for all confirmed external C2 destinations: 86.159.48.25 (Dridex, TCP 2222), 78.31.67.7 (DarkVNC/BackConnect, TCP 443), and 108.177.235.29 / jesofidiwi.com (TCP 443).
- Flush active firewall state tables to sever any remaining long-lived outbound sessions on TCP 2222 and TCP 443.
- On Domain Controller 10.11.28.2 (WIN-FGG5B8C1BYF.mytallbeer.com), review Security event logs (4624, 4625, 4672, 4768, 4769, 5140, 5145) for the account(s) responsible for the SMB/IPC\$/SYSVOL sessions and the 80 drsuapi calls, and confirm whether the source was an authorized administrator.

Additional Recommendations

- Network: Enforce default-deny egress filtering, restricting outbound traffic to approved standard ports (80/443 via inspected forward proxy); block direct outbound access to non-standard ports such as TCP 2222. Restrict SMB (139/445) and RPC (135, dynamic high ports) access to Domain Controllers to approved administrative source hosts only.
- Endpoint: Acquire full volatile memory and disk forensic images of workstation 10.11.28.101 to identify the resident Dridex and DarkVNC binaries, persistence mechanisms, and the process responsible for the drsuapi enumeration activity. Sweep the 10.11.28.0/24 segment for the same behavioral pattern on other hosts.
- Accounts / Credentials: Force password resets and invalidate Kerberos tickets (including KRBTGT-derived TGTs) for all accounts that authenticated from 10.11.28.101; audit and minimize membership of groups holding Replicating Directory Changes / Replicating Directory Changes All rights to reduce DCSync exposure.

- Active Directory: Disable NTLMv1 and restrict NTLM authentication domain-wide in favor of Kerberos with AES encryption. Enable/verify Advanced Audit Policy for Directory Service Access and Account Management on the Domain Controller, and adopt tiered administration so standard workstations cannot query drsuapi directly. Specifically alert on any future IDL_DRSGetNCChanges (DCSync) call.
- Recovery: Re-image workstation 10.11.28.101 from a verified golden baseline before rejoining the corporate network; monitor the Domain Controller for renewed IPC\$/drsuapi activity from the host post-remediation.